Kavalu Security Engine

WEB APPLICATION SECURITY ASSESSMENT REPORT

CONFIDENTIAL — for the recipient's authorized use only. This assessment covers only the automated checks listed in the Engine & Methodology section and does not constitute a complete penetration test.

Executive Summary

This assessment of http://127.0.0.1:42573/?id=1 identified 1 critical, 2 high-severity, 7 medium-severity and 3 low-severity finding(s), producing an overall risk score of 100.0/100 (Grade F — Critical Risk). The combined result set requires immediate remediation. Findings are organized below under their OWASP Top 10:2021 category with evidence, potential impact, and concrete remediation guidance for each.

Overall Risk Score	**100.0 / 100**
Risk Grade	**F — Critical Risk**
Findings (C / H / M / L / Info)	1 / 2 / 7 / 3 / 5
Target URL	http://127.0.0.1:42573/?id=1
Scan ID	960c9384-9f28-4f0e-80b8-cc3d9e601bd9
Assessment Engine	Kavalu Security Engine v2.0
Start Time	2026-11-03T01:38:14.458364
End Time	2026-11-03T01:38:14.602238

OWASP Top 10:2021 Coverage Matrix

Category	Name	Status	C	H	M	L
A01:2021	Broken Access Control	High-risk issues	0	1	2	0
A02:2021	Cryptographic Failures	High-risk issues	0	1	1	0
A03:2021	Injection	Critical issues	1	0	0	0
A04:2021	Insecure Design	No findings	0	0	0	0
A05:2021	Security Misconfiguration	Needs attention	0	0	3	2
A06:2021	Vulnerable and Outdated Components	Needs attention	0	0	1	0
A07:2021	Identification and Authentication Failures	No findings	0	0	0	0
A08:2021	Software and Data Integrity Failures	Needs attention	0	0	0	1
A09:2021	Security Logging and Monitoring Failures	No findings	0	0	0	0
A10:2021	Server-Side Request Forgery (SSRF)	No findings	0	0	0	0

Target Infrastructure & Developer Attribution

Deployed Platform	Practice target (tests/vulnerable_server.py)
Server Geolocation	Local machine
Server IP Address	127.0.0.1

Reverse DNS / Host	localhost
Web Server Header	BaseHTTP (sample)
Hosting Provider / ASN	N/A (sample data) (N/A)
Discovered Developer	Not disclosed in public metadata
Attribution Confidence	Low (Source: None)

Detailed Findings (18 total)

A01:2021 — Broken Access Control

[HIGH] Potentially Exposed Path: /.env

Exposed environment file — frequently contains credentials, API keys, or DB connection strings.

Type: exposed_path | CWE: CWE-538, CWE-200
path: .env · **url:** http://127.0.0.1:42573/.env · **status_code:** 200

Remediation: Block access to this path at the web-server/CDN level and remove it from the publicly served document root entirely.

[MEDIUM] Missing CSRF Protection

Form may lack CSRF protection: /login. Without a per-request token, an attacker-controlled page can trigger authenticated state-changing requests on a victim's behalf.

Type: csrf | CWE: CWE-352
form_action: /login · **form_method:** post

Remediation: Implement anti-CSRF tokens for all state-changing (POST/PUT/DELETE) operations, and set cookies with SameSite=Lax or Strict.

[MEDIUM] Potentially Risky HTTP Methods Enabled: PUT, DELETE, TRACE

The server advertises support for HTTP methods beyond GET/POST/HEAD. TRACE in particular can enable Cross-Site Tracing (XST) to read HttpOnly cookies in older browsers; PUT/DELETE without strict authorization can allow unauthorized content modification.

Type: http_method | CWE: CWE-650
allowed_methods: ["GET", "POST", "PUT", "DELETE", "TRACE"]

Remediation: Disable HTTP methods that are not explicitly required. Ensure any that remain enforce the same authentication/authorization as the main app.

A02:2021 — Cryptographic Failures

[HIGH] Target Not Served Over HTTPS

The target URL uses plain HTTP. All traffic, including any credentials or session identifiers, is transmitted unencrypted and can be intercepted or modified in transit (e.g. on shared Wi-Fi or by a network-level attacker).

Type: no_https | CWE: CWE-319
scheme: http

Remediation: Serve the site exclusively over HTTPS and redirect all HTTP requests to HTTPS with a permanent (301) redirect.

[MEDIUM] Cookie "sid" Missing Security Attributes

Cookie "sid" is set without: missing Secure flag, missing HttpOnly flag, missing SameSite attribute. This increases exposure to session hijacking (missing Secure/HttpOnly) or CSRF (missing SameSite).

Type: insecure_cookie | CWE: CWE-614, CWE-1004
cookie_name: sid · **issues:** ["missing Secure flag", "missing HttpOnly flag", "missing SameSite attribute"]

Remediation: Set Secure, HttpOnly, and SameSite=Lax (or Strict) on all session/auth cookies.

A03:2021 — Injection

[CRITICAL] SQL Injection Vulnerability

Potential SQL injection found in parameter "id". If exploitable, this class of flaw can let an attacker read, modify, or delete database contents — including other users' records — entirely bypassing the application's intended logic.

Type: sql_injection | CWE: CWE-89

parameter: id · **payload:** ' · **url:** http://127.0.0.1:42573/?id=%27 · **evidence:** Database error pattern detected: SQL syntax.*MySQL

Remediation: Use parameterized queries / prepared statements exclusively. Never concatenate user input into SQL strings. Apply least-privilege database accounts.

A05:2021 — Security Misconfiguration

[MEDIUM] Missing Strict-Transport-Security

HSTS header missing - site vulnerable to SSL stripping attacks

Type: security_header | CWE: CWE-16
header: Strict-Transport-Security · **present:** False

[MEDIUM] Missing Content-Security-Policy

CSP header missing - increases XSS attack surface

Type: security_header | CWE: CWE-16
header: Content-Security-Policy · **present:** False

[MEDIUM] Missing X-Frame-Options

X-Frame-Options missing - site may be vulnerable to clickjacking

Type: security_header | CWE: CWE-16
header: X-Frame-Options · **present:** False

[LOW] Missing X-Content-Type-Options

X-Content-Type-Options missing - browser may MIME-sniff content

Type: security_header | CWE: CWE-16
header: X-Content-Type-Options · **present:** False

[LOW] Missing Referrer-Policy

Referrer-Policy missing - referrer information may leak

Type: security_header | CWE: CWE-16
header: Referrer-Policy · **present:** False

[INFO] Missing Permissions-Policy

Permissions-Policy missing - browser features not restricted

Type: security_header | CWE: CWE-16
header: Permissions-Policy · **present:** False

A06:2021 — Vulnerable and Outdated Components

[MEDIUM] Outdated Front-End Library: jquery 1.12.4

Versions below 3.5.0 have known XSS issues (e.g. CVE-2020-11022/11023).

Type: outdated_component | CWE: CWE-1104, CWE-937
library: jquery · **detected_version:** 1.12.4 · **recommended_minimum:** 3.5.0 · **source:** https://cdn.example.com/jquery-1.12.4.min.js

Remediation: Upgrade jquery to 3.5.0 or later.

A08:2021 — Software and Data Integrity Failures

[LOW] Missing Subresource Integrity on 1 Cross-Origin Script(s)

Cross-origin <script> tags are loaded without an `integrity` attribute. If the third-party host or CDN is ever compromised, the served script content could change without the page detecting it.

Type: missing_sri | CWE: CWE-494
scripts: ["https://cdn.example.com/jquery-1.12.4.min.js"]

Remediation: Add Subresource Integrity (integrity + crossorigin) attributes to all cross-origin <script>/<link> tags, or self-host critical dependencies.

Remediation Roadmap

Immediate (Critical / High)

[A03:2021] SQL Injection Vulnerability: Use parameterized queries / prepared statements exclusively. Never concatenate user input into SQL strings. Apply least-privilege database accounts.

[A02:2021] Target Not Served Over HTTPS: Serve the site exclusively over HTTPS and redirect all HTTP requests to HTTPS with a permanent (301) redirect.

[A01:2021] Potentially Exposed Path: /.env: Block access to this path at the web-server/CDN level and remove it from the publicly served document root entirely.

Near-Term (Medium)

[A01:2021] Missing CSRF Protection: Implement anti-CSRF tokens for all state-changing (POST/PUT/DELETE) operations, and set cookies with SameSite=Lax or Strict.

[A01:2021] Potentially Risky HTTP Methods Enabled: PUT, DELETE, TRACE: Disable HTTP methods that are not explicitly required. Ensure any that remain enforce the same authentication/authorization as the main app.

[A02:2021] Cookie "sid" Missing Security Attributes: Set Secure, HttpOnly, and SameSite=Lax (or Strict) on all session/auth cookies.

[A06:2021] Outdated Front-End Library: jquery 1.12.4: Upgrade jquery to 3.5.0 or later.

Best Practice (Low / Info)

[A08:2021] Missing Subresource Integrity on 1 Cross-Origin Script(s): Add Subresource Integrity (integrity + crossorigin) attributes to all cross-origin <script>/<link> tags, or self-host critical dependencies.

Engine & Methodology

[RAN] Recon & Attribution: Deployment platform, hosting, and public developer-attribution discovery.
[RAN] OWASP Top 10 Injection Audit: Active non-destructive SQLi, XSS, Command Injection, and Path Traversal probes.
[RAN] SSL / TLS Cryptography: Certificate validity/expiry, cipher suites, protocol version, and HSTS checks.
[SKIPPED] Browser Automation (Selenium): Headless-browser DOM/console checks where available in the deploy target.
[RAN] Misconfiguration & Secrets Audit: Exposed .env, .git, backup archives, CORS, cookies, and HTTP methods audit.
[SKIPPED] Burp Suite Proxy Analysis: Traffic forwarding and analysis via a local Burp Suite proxy.
[RAN] Kavalu Detection Engine: Deterministic weighted risk-scoring and OWASP Top 10:2021 mapping of every finding above.

This report was produced by automated, non-destructive detection probes. It reflects the state of the target's publicly reachable surface at the time of the scan and is not a substitute for manual penetration testing, source-code review, or ongoing monitoring. Only scan systems you own or are explicitly authorized to test.

Authored by: Vinayaka N Walshettar